

# SPÉCIFICATIONS TECHNIQUES ET FONCTIONNELLES

## ZOLA MONEY TRANS v2.0 — Agrégateur de Paiement Marchand

### « Paiement Marchand »

#### 1. ARCHITECTURE TECHNIQUE GLOBALE

Zola Money Trans v2.0 adopte une architecture d'agrégateur de paiement en couches disjointes, garantissant qu'aucun fonds utilisateur n'est conservé par la plateforme. Chaque transaction est routée directement vers l'opérateur Mobile Money du payeur.

##### 1.1 Frontend — Interface utilisateur

| Technologie               | Rôle                                                         |
|---------------------------|--------------------------------------------------------------|
| HTML5 + CSS3              | Structure et design responsive — optimisé mobile (320px min) |
| JavaScript ES6+           | Logique client, orchestration API, validation formulaires    |
| Progressive Web App (PWA) | Installation sur écran d'accueil, mode hors-ligne partiel    |
| Service Workers           | Cache des ressources statiques, push notifications           |
| WebSocket (Firestore)     | Mises à jour temps réel du statut de transaction             |

##### 1.2 Backend — Firebase / Google Cloud Platform

| Service                               | Usage                                                                                 |
|---------------------------------------|---------------------------------------------------------------------------------------|
| Firebase Auth                         | Authentification : Email/Mot de passe, SMS OTP, 2FA. Sessions sécurisées.             |
| Firebase Cloud Functions (Node.js 18) | Logique métier : validation, routage transactions, calcul frais, webhooks partenaires |
| Firebase Firestore (NoSQL)            | Stockage : profils KYC, journaux transactions, catalogues marchands, réconciliation   |
| Firebase Cloud Messaging (FCM)        | Notifications push : confirmation paiement, alertes sécurité                          |
| Google Cloud Armor (WAF)              | Pare-feu applicatif, protection DDoS, filtrage IP malveillant                         |
| Google Cloud KMS                      | Gestion des clés cryptographiques, chiffrement AES-256                                |
| Google Cloud Monitoring               | Surveillance performance, alertes disponibilité, dashboards                           |

##### 1.3 Intégrations APIs Partenaires

| Partenaire     | Protocole           | Fonctions intégrées                                      | SLA cible |
|----------------|---------------------|----------------------------------------------------------|-----------|
| Vodacom M-Pesa | REST + OAuth2 + TLS | Initiation paiement, confirmation, remboursement, statut | 99.9%     |
| Airtel Money   | REST + OAuth2 + TLS | Initiation paiement, confirmation, remboursement, statut | 99.9%     |
| Orange Money   | REST + OAuth2 + TLS | Initiation paiement, confirmation, remboursement, statut | 99.9%     |

| Partenaire                     | Protocole             | Fonctions intégrées                              | SLA cible |
|--------------------------------|-----------------------|--------------------------------------------------|-----------|
| Rawbank / Equity Bank          | API bancaire REST     | Virement compte, confirmation, réconciliation    | 99.5%     |
| Flexpaie                       | REST + Webhook        | Routage paiement, recharges, services publics    | 99.5%     |
| SNEL / REGIDESO / Canal+ / MTN | API spécifique / USSD | Paiement factures, confirmation référence client | 99%       |

## 2. SPÉCIFICATIONS FONCTIONNELLES DÉTAILLÉES

### 2.1 Module Paiement Marchand (Produit Principal)

| Fonctionnalité            | Spécification Technique                                                                                       |
|---------------------------|---------------------------------------------------------------------------------------------------------------|
| QR Code statique marchand | Génération QR code PNG/SVG via bibliothèque qrcode.js. Encodage URL paiement avec ID marchand. T              |
| QR Code dynamique         | QR code généré à la volée avec montant pré-rempli. Validité configurable (5 min à 24h). Sécurisé par HM       |
| Lien de paiement          | URL courte (ex: pay.zolamoneytrans.com/m/CODE). Partage WhatsApp, SMS, email. Expiration configura            |
| Sélection opérateur       | Interface de sélection M-Pesa / Airtel / Orange avec logos et disponibilité temps réel. Opérateur suggéré s   |
| Redirection sécurisée     | Redirection vers interface opérateur Mobile Money (deeplink ou USSD). Retour automatique à Zola après         |
| Confirmation paiement     | Webhook de confirmation opérateur → mise à jour Firestore → notification push commerçant + reçu SMS           |
| Dashboard commerçant      | Vue temps réel : transactions du jour, total, statuts. Filtre par période, opérateur. Export CSV/Excel. Graph |

### 2.2 Module Passerelle Inter-Opérateurs

| Fonctionnalité        | Spécification                                                                                              |
|-----------------------|------------------------------------------------------------------------------------------------------------|
| Initiation transfert  | Saisie : montant, opérateur source, opérateur destination, numéro bénéficiaire. Validation KYC utilisateur |
| Calcul frais          | Affichage transparent des frais (fixes + %) avant confirmation. Frais selon corridor et montant.           |
| Exécution transaction | Débit opérateur source via API → crédit opérateur destination via API. Atomic transaction (rollback si éch |
| Réconciliation        | Matching automatique débit/crédit. Alertes sur écarts. Rapport quotidien.                                  |
| Délai traitement      | Instantané (<30 sec) pour M-Pesa ↔ Airtel ↔ Orange. Maximum 24h pour bancaire.                             |
| Historique            | Journal complet : date, heure, montant, frais, opérateurs, statut. Conservé 10 ans (réglementation BCC).   |

### 2.3 Module KYC (Know Your Customer)

| Niveau       | Conditions                                              | Limites                                |
|--------------|---------------------------------------------------------|----------------------------------------|
| KYC Basique  | Email vérifié + Numéro téléphone OTP + Pièce ID (photo) | 500 USD/mois — 100 USD/transaction     |
| KYC Avancé   | KYC Basic + Selfie biométrique + Adresse vérifiée       | 5 000 USD/mois — 1 000 USD/transaction |
| KYC Marchand | KYC Avancé + Documents entreprise + RCCM                | Illimité (selon plafonds BCC)          |

### 2.4 Module AML/CFT (Anti-Blanchiment)

- Surveillance temps réel : alerte automatique si transaction >2 000 USD
- Profiling comportemental par ML (TensorFlow.js) — détection anomalies
- Signalement automatique CENAREF pour transactions suspectes
- Blacklist / whitelist utilisateurs mise à jour en temps réel
- Rapport mensuel BCC généré automatiquement (format réglementaire)
- Conservation des alertes et décisions : 10 ans minimum

### 2.5 Module Sécurité

| Domaine          | Mesure                                                             | Standard            |
|------------------|--------------------------------------------------------------------|---------------------|
| Transport        | TLS 1.3 obligatoire — HTTP Strict Transport Security               | PCI-DSS / ISO 27001 |
| Données au repos | AES-256 — clés gérées Google KMS                                   | ISO 27001           |
| Authentification | SMS OTP + PIN 6 chiffres + 2FA biométrique optionnel               | NIST SP 800-63B     |
| Sessions         | Tokens JWT RS256, expiration 30 min, refresh sécurisé              | OAuth 2.0           |
| Pare-feu         | Google Cloud Armor — WAF, DDoS protection, rate limiting           | OWASP Top 10        |
| Fraude           | ML anomaly detection — seuils comportementaux — alertes temps réel | ISO 27001           |
| Audit            | Logs immuables — Cloud Audit Logs — piste d'audit complète         | Instruction BCC     |
| Tests            | Pentest semestriel par auditeur externe certifié CEH/OSCP          | ISO 27001           |

3. PROCÉDURES RÉGLEMENTAIRES QUOTIDIENNES

3.1 Conformité Quotidienne

- Vérification automatique des nouvelles inscriptions KYC (délai max 24h)
- Monitoring AML en temps réel — alertes traitées sous 2h par Compliance Officer
- Réconciliation automatique des transactions (débit/crédit) fin de journée
- Backup des données Firestore (RPO 1h, RTO 4h)
- Génération du rapport de flux journalier (archivage)

3.2 Conformité Mensuelle

- Rapport mensuel BCC : volumes, utilisateurs actifs, signalements AML
- Réconciliation financière complète (toutes transactions du mois)
- Revue des accès et permissions (principe du moindre privilège)
- Test de restauration backup
- Mise à jour des listes sanctions internationales (OFAC, UE, ONU)

4. PROCÉDURES DE GESTION DE CRISE

| Niveau            | Scénario                                               | Actions                                                       | Délai rapport BCC           |
|-------------------|--------------------------------------------------------|---------------------------------------------------------------|-----------------------------|
| 1 — Mineure       | Incident technique <15 min, <100 utilisateurs impactés | Identification → résolution → log incident                    | Non requis                  |
| 2 — Majeure       | Downtime >15 min ou fraude >10 ca                      | Direction complète → BCC notifié → communication utilisateurs | 24h                         |
| 3 — Critique      | Cyberattaque, downtime >2h, fraude >10 ca              | Direction + Avocat + Conseil Administration → BCC notifié     | Immédiat → CERT RDC         |
| 4 — Réglementaire | Ordre de suspension BCC                                | Compliance Officer 24/7 → exécution <2h → rapport action      | Immédiat → plan reprise 48h |

Plan de Continuité d'Activité (PCA)

- RPO (Recovery Point Objective) : 1 heure maximum
- RTO (Recovery Time Objective) : 4 heures maximum
- Redondance multi-région Firebase (Europe + US comme backup)
- Communication de crise : Slack interne + page statut publique + SMS utilisateurs
- Contact d'urgence 24/7 : Bob Nawej +243 993 242 872 | Dr Emmanuel Nduwa +243 857 767 040